Deployment & Operational Readiness Review

Nov 3, 2026 · @sanjay

Executive summary

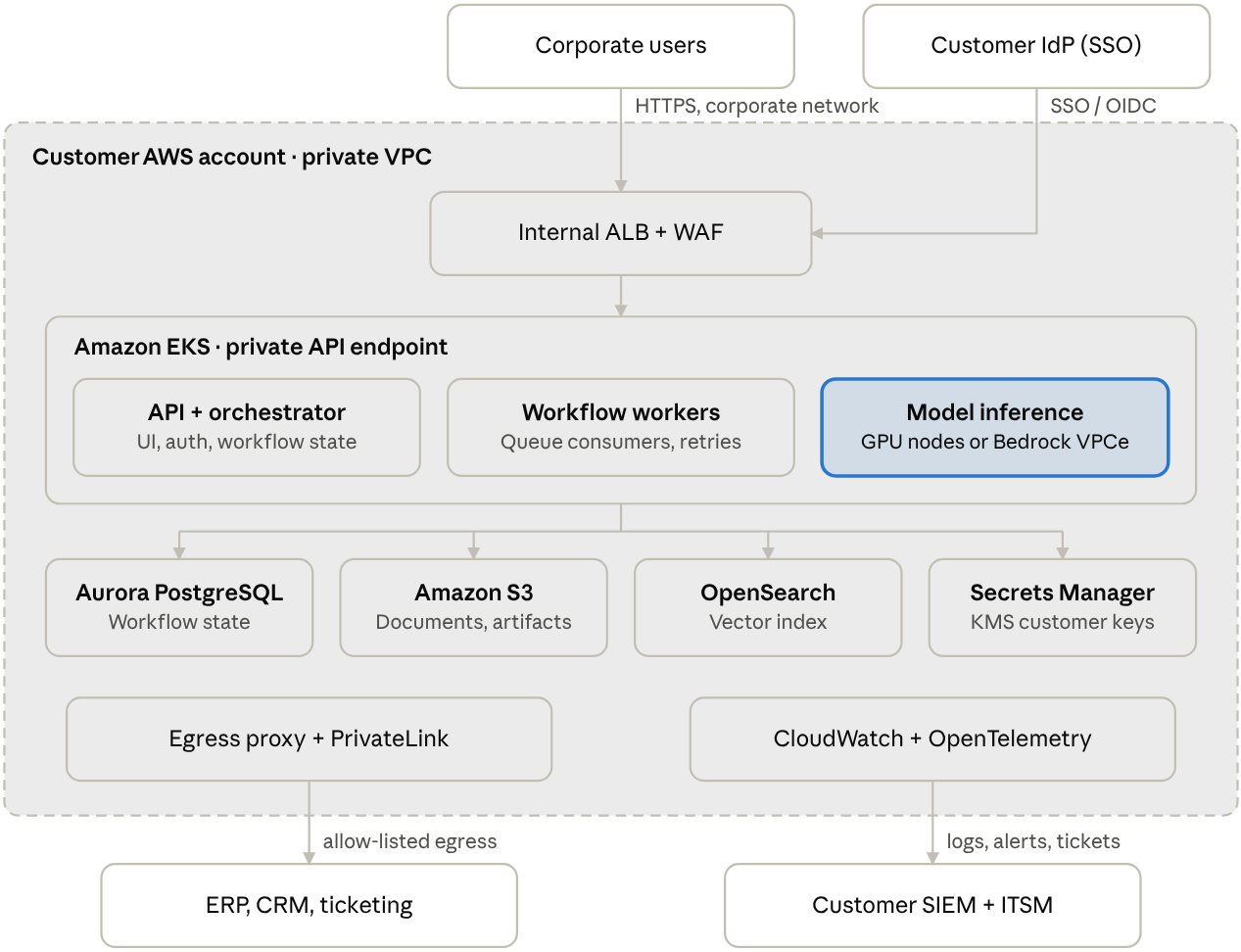
We recommend deploying the AI workflow automation platform as a **single-tenant stack inside the customer's own AWS account**, with no inbound internet exposure and model inference kept inside the customer's network boundary. The rollout runs in three phases over roughly 12 weeks, ending with the customer's platform team owning day-2 operations after a reverse-shadow handover and 90 days of hypercare.

This review covers the deployment model, customer constraints, identity and secrets design, operational readiness, the runbook, knowledge transfer, one productization opportunity, and the main risks. AWS is used as the reference platform; every component has an Azure or GCP equivalent if the customer standardizes elsewhere.

1. Deployment architecture

The platform runs as a customer-hosted, single-tenant deployment: our software, the customer's account, network, keys and data. Nothing is reachable from the public internet; users come in over the corporate network and the only egress is to allow-listed endpoints.

Users, model and data stay inside the customer account



reference architecture · single-tenant, customer AWS account

Everything inside the dashed boundary is owned by the customer; the only paths out are SSO, allow-listed egress to business systems, and telemetry to the customer's own SIEM.

Layer	Component	Notes
Network	Dedicated VPC, private subnets across 3 AZs	Reached via Transit Gateway / Direct Connect; no internet gateway on workload subnets
Ingress	Internal Application Load Balancer + WAF	TLS 1.2+, certificates from the customer's private CA, SSO in front of the UI

Layer	Component	Notes
Compute	Amazon EKS (private API endpoint)	Separate node groups for API/orchestrator, workers, and GPU inference
AI inference	Self-hosted model on GPU nodes, or Amazon Bedrock via VPC endpoint	Choice depends on data-residency policy; prompts never leave the account
Workflow engine	Orchestrator + queue (Amazon SQS)	Retries, dead-letter queues, idempotent task handlers
Data	Aurora PostgreSQL, S3, OpenSearch (vector index)	Encrypted with customer-managed KMS keys; versioned, cross-AZ
Integrations	Connectors to ERP/CRM/ticketing via PrivateLink or egress proxy	Each connector has its own scoped service identity
Delivery	GitOps (Argo CD) from signed images in a private registry (ECR)	Infrastructure as code (Terraform); no manual console changes in prod

Three environments — **dev, staging, prod** — live in separate AWS accounts under the customer's AWS Organization, so a mistake in one cannot reach another. Promotion is by Git tag only, with staging mirroring prod configuration.

2. Customer constraints

The design is shaped by three groups of constraints; each one maps to a specific design decision.

Type	Constraint	How the design meets it
Infrastructure	Must run on customer-owned private infrastructure	Deployed into customer AWS accounts; vendor has no standing access
Infrastructure	No public endpoints; restricted egress	Internal load balancer, VPC endpoints, egress proxy with an allow-list

Type	Constraint	How the design meets it
Infrastructure	Customer change-management windows	All changes via pull request and CAB-approved release windows
Security	Corporate SSO and MFA for every user	OIDC/SAML federation to the customer IdP (e.g. Entra ID, Okta)
Security	Customer controls encryption keys	Customer-managed KMS keys; key policies owned by customer security
Security	Data residency and no training on customer data	In-account inference; model provider contract excludes training; region-pinned storage
Security	Audit evidence for governance (e.g. SOC 2, ISO 27001 controls)	CloudTrail, immutable log archive, quarterly access reviews
Operational	Customer platform team owns operations after launch	Runbooks, dashboards and on-call built into the handover plan
Operational	Existing tooling must be reused	Logs and alerts forward to the customer's SIEM and ITSM (e.g. Splunk, ServiceNow)
Operational	Defined availability target	99.9% for the workflow API; RPO 15 min, RTO 4 h

The availability and recovery targets above are proposed starting points to confirm with the customer during discovery.

3. IAM strategy

Access follows least privilege, with humans federated through the customer IdP and workloads using short-lived, role-based identities — no long-lived access keys anywhere.

Role	Who	Permissions	Prod access
Platform Admin	Customer platform team (2–3 named people)	Manage infrastructure, deployments, IAM roles	Break-glass only, time-boxed, MFA

Role	Who	Permissions	Prod access
Operator / SRE	Customer on-call engineers	Read logs and metrics, restart workloads, run runbook actions	Standard, via SSO session
Workflow Builder	Business automation team	Create and edit workflows in non-prod; submit for promotion	Read-only
Approver	Process owners	Approve workflow promotion to prod	Approve only
End User	Business staff	Run and monitor their own workflows	App-level only, no cloud console
Auditor	Security / compliance	Read-only logs, configs and access reports	Read-only
Vendor Engineer	Our deployment team	Full access in dev/staging; none in prod after handover	Just-in-time, ticket-linked, recorded

Controls

- **Human access:** SSO via AWS IAM Identity Center mapped to IdP groups; group membership is the single source of truth, so leavers lose access automatically.
- **Workload access:** EKS service accounts with IAM Roles for Service Accounts (IRSA); each service and each connector gets its own role scoped to the resources it needs.
- **Guardrails:** Service Control Policies block disabling CloudTrail, deleting KMS keys or creating public resources.
- **Application RBAC:** workflow-level permissions and data scoping so users only see workflows and records their group owns.
- **Reviews:** quarterly access recertification and alerts on any use of break-glass roles.

4. Secrets management

All credentials live in **AWS Secrets Manager**, encrypted with customer-managed KMS keys, and are never stored in code, container images, CI variables or tickets. HashiCorp Vault is an equally valid choice if the customer already runs it.

- **Delivery to workloads:** the External Secrets Operator syncs secrets into pods at runtime; each service's IAM role can read only its own secret paths.
- **Prefer no secret at all:** AWS services are reached with IAM roles; databases use IAM authentication where supported.
- **Rotation:** database and integration credentials rotate automatically every 30–90 days; API tokens for third-party systems rotate on a schedule agreed with each system owner.
- **Encryption:** TLS in transit everywhere, including inside the cluster (service mesh mTLS); KMS encryption at rest for databases, S3, queues and backups.
- **Sensitive data in the AI path:** PII is redacted or tokenized before prompts where possible, prompts and outputs are logged only in redacted form, and the model is never fine-tuned on customer data without written approval.
- **Detection:** secret scanning in CI (e.g. gitleaks) blocks merges that contain credentials; CloudTrail alerts on unusual secret reads.
- **Revocation:** a runbook procedure rotates any suspected-leaked secret within 1 hour.

5. Operational readiness

The system is ready for production only when monitoring, support and incident response are in place and have been exercised — not just configured.

Monitoring and observability

- **Metrics:** Prometheus/CloudWatch for platform health (latency, error rate, queue depth, GPU utilization) plus AI-specific signals: model latency, token usage and cost, output validation failures, and human-override rate.
- **Logs and traces:** OpenTelemetry traces across each workflow run; structured logs forwarded to the customer SIEM.
- **SLOs:** workflow API availability 99.9%; p95 task start under 5 seconds; error budget reviewed monthly.
- **Alerts:** tied to SLO burn rate and routed through PagerDuty or the customer's on-call tool; every alert links to a runbook entry.

Support model

Tier	Owner	Scope
L1	Customer service desk	User access, how-to questions, ticket triage

Tier	Owner	Scope
L2	Customer platform team	Runbook actions, restarts, connector issues, rollbacks
L3	Vendor engineering	Product defects, model behaviour, patches — under support contract

Incident response

Severity	Example	Response target	Update cadence
Sev 1	Platform down or data exposure	15 min	Every 30 min
Sev 2	Key workflow failing, no workaround	1 h	Every 2 h
Sev 3	Degraded performance, workaround exists	1 business day	Daily

Each incident has a named incident commander, a comms channel, and a blameless post-incident review within 5 business days. Security incidents follow the customer's security incident process from the first minute.

Go-live readiness gate: load test at 2× expected peak, a restore-from-backup test, one failover test, one game-day incident simulation, and a passed security review and penetration test.

6. Runbook design

The runbook is a version-controlled repository (Markdown in Git, published to the customer wiki) written so an on-call engineer who did not build the system can act on it at 3 a.m.

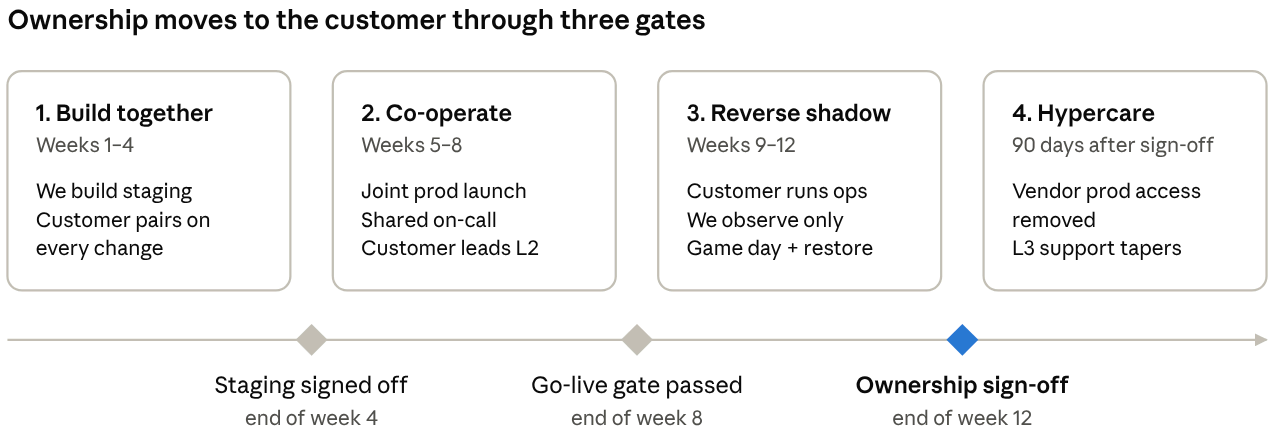
1. **System overview** — architecture diagram, components, dependencies, data flows, owners and escalation contacts.
2. **Access** — how to get standard and break-glass access, and who approves it.
3. **Standard operations** — deploy, roll back, scale node groups, add a connector, promote a workflow, rotate a secret, renew certificates.
4. **Alert playbooks** — one page per alert: what it means, how to confirm, step-by-step fix, when to escalate.

5. **Failure scenarios** — model endpoint unavailable (fall back to queue-and-retry or human review), queue backlog, database failover, integration outage, runaway token cost, bad model output in production (disable the workflow via feature flag).
6. **Backup and disaster recovery** — what is backed up, how often, and the tested restore procedure against the RPO/RTO.
7. **Security procedures** — suspected credential leak, suspicious access, data-exposure response, evidence preservation.
8. **Routine maintenance** — patching cadence, model and dependency upgrades, cost review, quarterly access review.
9. **Change log and review** — every runbook entry has an owner and a last-tested date; entries untested for 6 months are flagged.

Each entry follows the same template: *Trigger → Impact → Diagnosis → Actions → Verification → Escalation*.

7. Knowledge transfer plan

Ownership moves from our team to the customer's platform team in three phases plus hypercare, with an explicit exit gate at each step so the handover is earned, not assumed.



handover roadmap · 3 phases, 3 gates, then hypercare

The customer does not take ownership until the sign-off gate is met; hypercare then gives a safety net while vendor involvement tapers off.

The customer names a **platform owner** and at least **two trained engineers** before Phase 2 starts, so no single person becomes the only one who knows the system.

Methods

- **Pairing on real work:** customer engineers build staging alongside us, not from slides.
- **Recorded walkthroughs:** architecture, deployment, and each alert playbook, stored with the runbook.
- **Hands-on labs and game days:** at least one simulated Sev 1 and one restore-from-backup run by the customer team.
- **Documentation handover:** runbook, architecture decision records, IaC repositories and dashboards transferred to customer-owned repos and accounts.
- **Access handover:** vendor access in prod is removed at sign-off and replaced by just-in-time L3 access.

Success criteria for sign-off: the customer team resolves two real or simulated incidents without vendor help, ships one production release on its own, and scores at least 80% on an operational readiness checklist.

After sign-off, a 90-day hypercare period gives the customer priority L3 support and a weekly review that tapers to monthly.

8. Productization opportunity

Turn this deployment into a "Private Deployment Kit": a reusable, opinionated landing-zone package for running the platform in any customer's cloud account.

Most of the effort in this engagement is not specific to this customer: private networking, IdP federation, KMS and secrets wiring, observability, and the runbook are needed by every regulated enterprise. Today that work is rebuilt per project.

The kit would include:

- Versioned Terraform modules and a Helm chart for the full stack, with secure defaults (private endpoints, IRSA, customer-managed keys, SCP guardrails).
- A preflight checker that validates a customer account against prerequisites (quotas, networking, IdP, GPU capacity) before day one.
- Pre-built dashboards, SLO alert rules, and a runbook template that ships with the release.
- A security and compliance evidence pack mapped to common controls, to shorten customer security reviews.
- A knowledge-transfer curriculum with labs and a readiness checklist.

Expected value: shorter time to production for the next private deployment (target: from about 12 weeks to 4–6), fewer configuration-drift support tickets, and a stronger answer in enterprise security reviews. Customer-specific pieces from this project (connectors, approval rules) are reviewed before inclusion so nothing confidential is generalized.

9. Risk assessment

The highest risks are a weak handover and AI-specific failures, because both surface only after launch when the vendor team has stepped back.

Risk	Type	Likelihood	Impact	Mitigation
Customer team not ready to own operations at handover	Operational	Medium	High	Exit gates per phase, named owners, reverse-shadow period, 90-day hypercare
Model produces incorrect or unsafe actions in a workflow	Operational / AI	Medium	High	Output validation, human approval for high-impact steps, feature-flag kill switch, quality monitoring
Sensitive data exposed through prompts, logs or outputs	Security	Low	High	In-account inference, PII redaction, redacted logging, data-loss alerts
Credential leak or over-privileged service identity	Security	Medium	High	Secrets Manager, IRSA per service, secret scanning, rotation, quarterly access review
Prompt injection via documents or integrated systems	Security / AI	Medium	Medium	Treat external content as untrusted, restrict tool permissions per workflow, allow-listed actions

Risk	Type	Likelihood	Impact	Mitigation
GPU capacity shortage or runaway inference cost	Operational	Medium	Medium	Reserved capacity, autoscaling limits, per-workflow budgets and cost alerts
Upstream integration outage (ERP, CRM)	Operational	Medium	Medium	Queues with retries and dead-letter handling, circuit breakers, clear user messaging
Configuration drift from manual changes	Operational	Medium	Medium	GitOps only, SCPs, drift detection in CI
Vendor access lingers after handover	Security	Low	High	Access removal in the sign-off checklist; just-in-time, logged L3 access only
Model or dependency upgrades break workflows	Operational	Medium	Medium	Staging regression suite of golden workflows, canary releases, fast rollback

Risks are tracked in a shared register owned by the customer platform owner and reviewed at every phase gate and monthly during hypercare.